

Fundamentos de Criptografia e Segurança da Informação

Licenciatura em Ciências da Computação

José Bacelar Almeida

Applied Cryptography

Symmetric Crypto

Asymmetric Crypto

Applications

Conteúdo

- Acordo de Chaves
 - Protocolo Diffie-Hellman
- Criptografia de chave pública
 - Cifra de chave pública (PKE)
 - Assinatura Digital (PKS)
 - Primitivas
- Criptografia baseada em Curvas Elípticas (ECC)
- Criptografia e Computação Quântica
 - Criptografia Post-Quantum (PQC)

Acordo de Chaves

Contexto

- A criptografia simétrica depende de chaves secretas partilhadas;
 - O pré-acordo de chaves é um procedimento caro (requer o uso de canais seguros...) e pouco flexível.
 - Existem alternativas viáveis?
 - E.g.: Suponha que tenhamos uma cifra (simétrica) na qual a operação de cifra é comutativa, i.e. $E_{k1}(E_{k2}(X))=E_{k2}(E_{k1}(X))$
 - Cada parte (A e B) gera uma chave secreta (K_A e K_B , respectivamente)
 - Para A comunicar M com B , pode:
 - A envia $E_{K_A}(M)$ to B — (note that K_A is only known by A);
 - B envia $E_{K_B}(E_{K_A}(M))=E_{K_A}(E_{K_B}(M))$ to A — (again, K_B is only known by B);
 - A decifra a mensagem recebida, e reenvia o resultado $E_{K_B}(M)$ a B ;
 - B finalmente decifrar o criptograma com a sua chave, obtendo a mensagem M .
- ... ou seja, A e B comunicam de forma secreta sem nunca trocarem segredos... (mensagem M está sempre protegida com, pelo menos, um nível de cifra).
- Obs: Mas este esquema exhibe vulnerabilidades importantes... (cf. ataque man-in-the-middle estudado abaixo)

Acordo de Chaves

- O problema da distribuição de chaves pode ser contornado se ambas as partes concordarem com um segredo comum...
 - ...trocando mensagens em um canal público...
 - ...mas sem ser possível derivar o segredo observando as mensagens trocadas.
- Um esquema que acomoda esses requisitos apareceu no artigo (*New Directions in Cryptography*, Diffie & Hellman 1976).
- A segurança do esquema aí apresentado decorre da exponenciação modular poder ser considerada de “sentido único” (dificuldade do logaritmo discreto).

Intermezzo: Estruturas Algébricas

- Quando p é um número primo, $GF(p)=(\mathbb{Z}_p, +, *)$ é um **corpo** ($+$ e $*$ são respectivamente a adição e multiplicação modulo p).
 - Inversa modular pode ser calculada pelo algoritmo de Euclides (estendido);
 - Um elemento primitivo é um **generator** g do grupo multiplicativo (i.e., cada elemento não nulo pode ser escrito como g^i , para algum i).
- Para um número n composto, $(\mathbb{Z}_n, +, *)$ forma um **anel**.
 - Elementos com inversa multiplicativa (**units**) são os x tais que $\gcd(x, n)=1$ (*primos relativos a n*).
 - O número desses elementos é dado por $\phi(n)$ (Euler function).

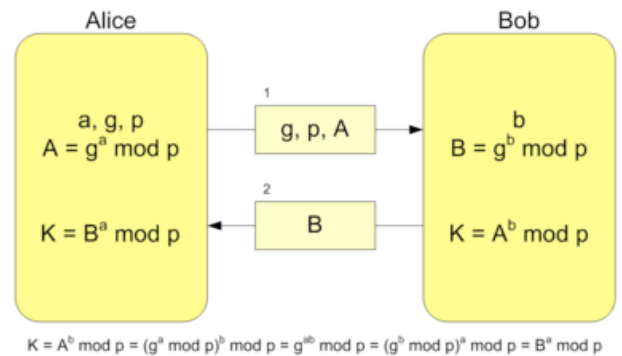
Problemas difíceis

Sob condições apropriadas, os seguintes problemas são considerados difíceis.

- **Factorização de inteiros**
 - Dado um inteiro n , determine sua factorização em números primos, i.e., determinar números primos $p_1, \dots, p_i$ such that $p_1 \times \dots \times p_i = n$.
- **Logaritmo discreto**
 - Dado a , b e n , calcular x tal que $a^x \bmod n = b$.
- **Raiz quadrada discreta**
 - Dado y e n , calcular x tal que $x^2 \bmod n = y$.

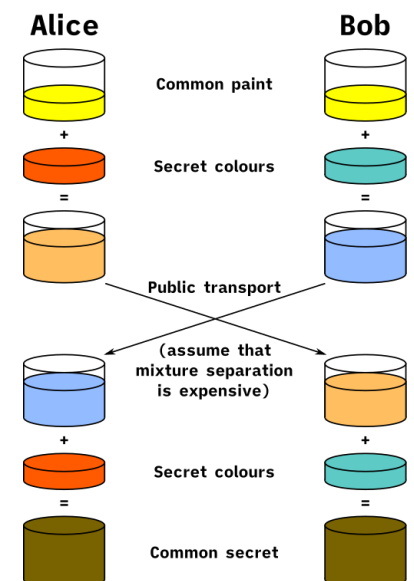
Protocolo Diffie&Hellman (Efémero)

- Parâmetros:
 - Deixe p ser um primo e g um gerador de um subgrupo de Z_p^* com ordem prima q .
- Descrição:
 - A escolhe aleatoriamente um inteiro $sk_A=x$ t.q. $1 < x < q$ (**private key**), enviando $pk_A=g^x \bmod p$ (**public key**) a B .
 - De forma análoga, B escolhe aleatoriamente $sk_B=y$ t.q. $1 < y < q$, enviando $pk_B=g^y \bmod p$ a A .
 - Shared secret:** $K=g^{xy} \bmod p = (g^x)^y \bmod p = (g^y)^x \bmod p$.
- Note que cada parte gera um par de chaves para cada execução do protocolo — daí o qualificador “Efémero”.
- Obs.: o segredo acordado K nunca deve ser usado diretamente como uma chave criptográfica. Em vez disso, deve ser usada uma KDF para, a partir dele, derivar as chaves necessárias.



segurança do DH perante Adversários Passivos

- Se o adversário puder calcular o logaritmo discreto, pode também calcular x from g^x , que resultaria num ataque ao protocolo.
- ...mas acredita-se que tal operação não é viável!
- De forma mais rigorosa, a segurança do protocolo é expressa como uma assumpção de segurança própria - o problema **Computacional Diffie-Hellman (CDH)**: para x e y aleatórios, é inviável para um adversário PPT calcular g^{xy} a partir de g^x e g^y .



Insegurança do DH perante Adversários Activos

- Um adversário ativo pode realizar o papel da outra parte no protocolo e, assim, comprometer o sigilo do segredo partilhado — conhecido como ataque **man-in-the-middle**.

- Exemplo:

Suponha que A queira concordar em um segredo com B :

- A gera o par de chaves $(sk_A, pk_A) = (x, g^x)$, enviando pk_A a B ;
 - I intercepta a mensagem enviada por A ;
 - I gera o seu próprio par de chaves $(sk_I, pk_I) = (z, g^z)$, retornando pk_I a A ;
 - A adopta como segredo partilhado $K = (g^z)^x = g^{xz}$, que presume partilhado com B ;
 - ...mas afinal foi partilhado com I , que o calcula como $K = (g^x)^z = g^{xz}$.
- A maioria das técnicas criptográficas assimétricas são vulneráveis a esse ataque!

O uso da criptografia assimétrica depende de uma associação confiável entre chaves públicas e as partes legítimas (identidades).

Cifra de Chave Pública

Cifra de Chave Pública

- O artigo que apresentou o protocolo DH sugeriu outras possíveis aplicações do mecanismo subjacente: a divisão da chave em dois componentes (um **par de chaves**):
 - Uma chave que permanece secreta — **secret-key (sk)**
 - Outra que pode ser tornada pública — **a public-key (pk)** —, sendo que não deverá ser possível obter informações da chave privada a partir dela.
- Note que:
 - Chaves secretas não precisam (nem devem) ser partilhadas
 - Não é necessário garantir o sigilo das chaves públicas — podem ser transmitidas por um canal aberto.
 - Mas permanecem os problemas sobre a autenticidade das chaves públicas, como no caso do protocolo DH...

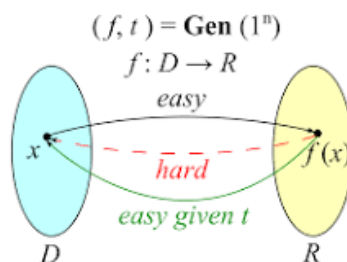
Public-Key Encryption (PKE)

- Podemos extrapolar o impacto das mudanças mencionadas acima nas cifras — **Public-Key Encryption (PKE)**.
 - *Bob* gera um par de chaves: $(sk_B, pk_B) = \text{KeyGen}()$
 - *Bob* envia pk_B a *Alice* (ou *Alice* tem acesso a ela por algum meio...);
 - *Alice* cifra uma mensagem a *Bob* usando a sua chave pública:
$$C = \text{Enc}(pk_B, M)$$
 - *Bob* decifra o criptograma usando a sua chave privada:
$$M' = \text{Dec}(sk_B, C)$$
- Claramente, esperamos que:

$$\text{Dec}(sk_B, \text{Enc}(pk_B, M)) = M \quad (\text{critério de correção})$$

One-way trapdoor permutations

- Do ponto de vista da segurança, traduz-se num refinamento de funções de sentido único com um requisito adicional— o que se designa por **one-way trapdoor permutation**:
 - cifrar com a chave pública deve ser uma função de sentido único
 - a menos que se conheça a chave privada correspondente (que permite realizar a operação inversa)



Man-in-the-middle (II)

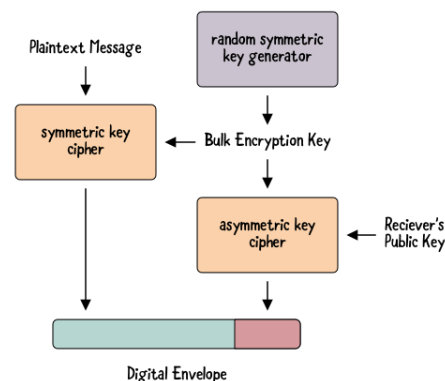
- Como mencionado, PKE não escapa ao problema das chaves públicas não serem autênticas...
- i.e., é vulnerável ao ataque man-in-the-middle:
 - *Adversário* intercepta a chave pública de *Bob* (pk_B), trocando-a pela dele próprio (pk_I);
 - *Alice* calcula $C = \text{Enc}((pk_I), M)$, acreditando que só *Bob* pode decifrar;
 - *Adversário* intercepta criptograma e decifra-o usando a sua chave privada:
 $M' = \text{Dec}(sk_I, C)$;
 - ... podendo ainda envia-la (possivelmente manipulada) a *Bob*.
- Reforça o mote: **a criptografia assimétrica depende de chaves públicas autênticas.**

Cifra Híbrida

- Um esquema PKE só é capaz de lidar com mensagens com uma forma restrita.
- Mas, ao contrário das cifras de bloco, em que se recorre a um modo de operação para processar mensagens arbitrárias, considerações de eficiência e segurança levam a uma estratégia alternativa...

Cifra Híbrida (ou **Envelope Digital**) combina o uso de uma cifra simétrica com um esquema PKE assimétrico.

- A cifra simétrica é usada para cifrar a mensagem com uma chave aleatória;
- Reservando-se, para a criptografia assimétrica, a protecção da chave simétrica utilizada.



Paradigma KEM/DEM

- O paradigma KEM/DEM estrutura a estratégia de criptografia híbrida, abrindo caminho para uma análise de segurança mais abrangente.
- Um **KEM/DEM** consiste em dois components:
 - **Key Encapsulation Mechanism (KEM)** — um esquema de chave pública que é desenhado para gerar chaves secretas (simétricas) e respectivo encapsulamento (recorrendo a PKE=).
 - KeyGen : $\text{SecParam} \rightarrow (\text{SecKey}, \text{PubKey})$
 - Encap: $\text{PubKey} \rightarrow (\text{SymKey}, \text{CipherText})$
 - Decap: $(\text{SecKey}, \text{Ciphertext}) \rightarrow \text{SymKey}$
 - **Data Encapsulation Mechanism (DEM)** — um esquema simétrico que usa a chave gerada pelo KEM (tipicamente, uma cifra autenticada).

Assinaturas Digitais

- Trocando os papéis de chaves públicas/secretas no PKE torna possível definir um análogo digital de assinatura de documentos.
- **Frequentemente reconhecida como a principal contribuição da criptografia assimétrica.**
- Propriedades:
 - *Integridade*: a mensagem não é modificada após a assinatura;
 - *Autenticidade*: a identidade do signatário pode ser confirmada;
 - **Não repúdio**: é possível “provar” a identidade do signatário.
- Obs. 1: a essência do conceito de assinatura digital é a assimetria entre as capacidades do verificador e do signatário: o primeiro deve ser capaz de verificar as assinaturas produzidas pelo último sem ter a capacidade de as produzir ele mesmo. Note que os MACs garantem os dois primeiros requisitos, mas falham no último (não repúdio) — nesse caso, o verificador tem tanta informações quanto o signatário.
- Obs. 2: como iremos ver, é a capacidade das assinaturas digitais “autenticarem documentos” que tornará possível superar as limitações das técnicas assimétricas atrás identificadas...

Digital Signature Scheme

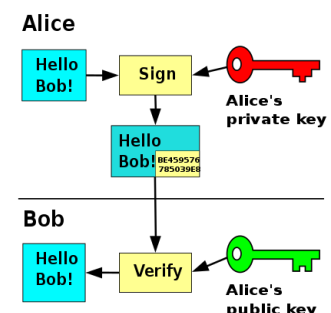
- Duas entidades: o *a(S)sinante* e o *(V)erificador*.
- Um esquema de assinatura compreende três operações:

- $\text{keyGen}: \text{secParam} \rightarrow \text{secretKey} * \text{pubKey}$
- $\text{sign}: \text{secretKey} * \text{message} \rightarrow \text{signature}$

obs.: a assinatura é anexada à mensagem — a mensagem assinada é, portanto, o par (M, sig) ;

- $\text{verify}: \text{pubKey} * (\text{message} * \text{signature}) \rightarrow \text{Bool}$

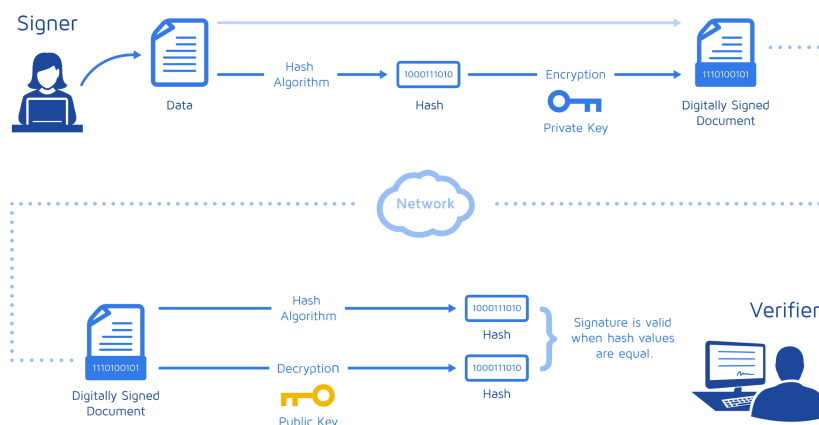
- Propriedades (par de chaves do assinante: (sk^S, pk^S)):
 - **Correcção**: $\forall M, \text{verify}(pk^S, (M, \text{sign}(sk^S, M))) = \text{true}$
 - **Segurança**: sem o conhecimento de sk^S é inviável “forjar” a assinatura σ para qualquer mensagem M tal que $\text{verify}(pk^S, (M, \sigma)) = \text{true}$



Assinaturas e Hash

- Assim como no PKE, as assinaturas são sempre combinadas com primitivas simétricas.

As funções Hash criptográficas são usadas para mapear o conteúdo de mensagens arbitrárias em resumos de tamanho fixo (valores hash)



Man-in-the-middle (III)

- Mas, como noutras técnicas assimétricas, as assinaturas digitais são vulneráveis a ataques man-in-the-middle.
- Em assinaturas, este ataque traduz-se numa falha de validação da identidade do signatário (a verificação é realizada com a chave pública “errada”).
- Observe, no entanto, que estamos novamente num ponto onde é patente algum tipo de circularidade entre qual é o objetivo da técnica e a causa do problema:
 - A assinatura digital destina-se a estabelecer a autenticidade de uma mensagem/documento...
 - ...e a falha em garantir a autenticidade da associação entre chaves públicas e identidades leva à possibilidade de um ataque man-in-the-middle.
- Então:
 - Se considerarmos uma **entidade confiável** que estabeleça a associação entre identidades e chaves públicas num qualquer tipo de “documento”...
 - ...podemos recorrer às assinaturas digitais para estabelecer a autenticidade dessas associações.

Certificação de Chave Pública

- A criptografia assimétrica depende da associação entre chaves públicas e identidades dos agentes. É certo que tal garantia poderia ser alcançada através da pré-distribuição das chaves públicas (mas não estaríamos longe do problema geral da pré-distribuição de chaves...)
- Uma abordagem mais interessante consiste em recorrer aos próprios mecanismos fornecidos pela criptografia assimétrica (especificamente, assinaturas digitais) para estabelecer associações de chave pública/identidade:
 - Todos os agentes confiam numa terceira parte — a **Autoridade de Certificação (CA)** ou Entidade Certificadora (EC). A chave pública dessa entidade deve ser obtida por algum canal seguro.
 - A CA garante (assinando digitalmente) a associação entre a chave pública e identidade do agente — o que chamamos de **certificado de chave pública**. A CA é responsável por garantir a correção dessa associação.
 - Qualquer entidade pode verificar a assinatura de um certificado (atestando assim a validade da associação estabelecida).

Uso de certificados

- O uso de certificados adiciona um ónus considerável à gestão de chaves.
 - Criação de Certificado (e.g. para Alice):
 - Alice um par de chaves (sk^A, pk^A);
 - Alice solicita um certificado para a sua chave pública (pk^A) a uma CA (da sua escolha);
 - CA realiza as diligências devidas para estabelecer a exatidão das informações a serem incluídas no certificado (que a chave privada associada pk^A está efectivamente na posse de Alice);
 - CA assina o certificado contendo a associação ($Alice, pk^A$), devolvendo-o a Alice.
 - Uso do Certificado (e.g. assinatura):
 - Alice envia a Bob documento assinado juntamente com seu próprio certificado;
 - Bob valida certificado recebido, consultando depois a chave pública de Alice nele contido.
- Utilização de certificados parte do pressuposto que os pares de chaves são de longo prazo.
 - Este é de fato o caso de pares de chaves usados em PKE e Assinaturas Digitais;
 - Mas não para o protocolo Diffie-Hellman (Efémero)...

Protocolo *Station-to-Station*

- O protocolo Diffie-Hellman (efémero) requer que os pares de chaves sejam gerados para cada execução do protocolo.
- Em vez de certificar diretamente as chaves públicas do DH, pode-se garantir a autenticidade de cada parte recorrendo a assinaturas digitais normais (e certificados correspondentes).
- O protocolo resultante é designado por *Station-to-Station*
 - $A \rightarrow B: +x . g^x$
 - $B \rightarrow A: +y . g^y, E_K(\text{sig}(sk^B, (g^y || g^x))), \text{Cert}^B$
 - $A \rightarrow B: E_K(\text{sig}(sk^A, (g^x || g^y))), \text{Cert}^A$
- Notação: " $A \rightarrow B: +x . M$ " Denota um passo na qual A gera o valor x e envia a B a mensagem M ; $E_K(M)$ denota o criptograma resultante da cifra de M com a chave simétrica acordada (derivada de $K=g^{x*y}$); e $\text{sig}(sk^A, M)$ a assinatura digital de M por A (assume-se que devidamente verificada na recepção).

Primitivas Assimétricas

primitiva RSA

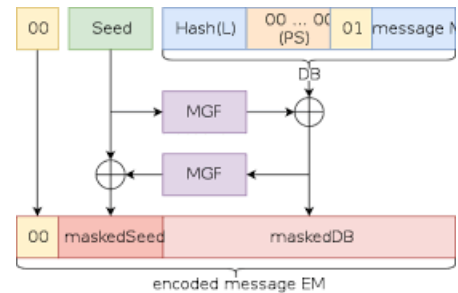
- Algoritmo que realiza o conceito de criptografia de chave pública introduzido por *Diffie & Hellman*, proposto por *Ron Rivest, Adi Shamir & Leonard Adleman* (1977/8).
- A segurança é baseada na dificuldade de fatorizar números grandes.
- Descrição:
 - KeyGen():
 - gerar aleatoriamente dois primos p and q ;
 - Seja $n=p*q$ (logo, $\phi(n)=(p-1)*(q-1)$), e escolha e tal que $\gcd(e,n)=1$;
 - calcular d tal que $e*d=1 \bmod \phi(n)$;
 - retornar (sk, pk) , onde a chave secreta $sk = (n, d)$; e a chave pública $pk = (n, e)$.
 - $RSA(pk=(n, e), m) = m^e \bmod n$
 - $RSA^{-1}(sk=(n, d), c) = c^d \bmod n$
- Pode ser usado tanto em PKE como em Assinaturas Digitais.

Segurança RSA

1. Pode-se demonstrar que derivar a chave secreta a partir da chave pública é equivalente à fatorização de $n=p*q$.
 2. Acredita-se que inverter $RSA(pk, m)$ sem o conhecimento da chave secreta sk é difícil para uma mensagem m aleatória (no espaço de mensagens $0 \leq m < n$) — **assumpção RSA**.
 3. No entanto, é trivial quebrar o RSA se m for escolhido de um espaço de mensagens pequeno (e.g. um bit)!
 - Isso é, de fato, uma consequência do determinismo da primitiva RSA (ou seja, uma determinada mensagem cifrada repetidamente sempre resulta no mesmo criptograma).
- Tamanhos típicos das chaves: acredita-se que um modulus n com 3072 bit oferece um nível de segurança similar ao AES-128.
 - Podemos assim extrapolar uma grande diferença na eficiência da criptografia simétrica e assimétrica - a primeira é tipicamente milhares de vezes mais rápida do que a segunda (para um determinado nível de segurança).
 - O determinismo do RSA (bem como outras propriedades decorrentes da estrutura interna do algoritmo) determina que deve sempre ser adotado um esquema de *padding* na mensagem.

Variante aleatórias do RSA

- O *padding* usado no RSA cumpre dois objectivos:
 1. adicionar aleatoriedade à mensagem cifrada;
 2. adicionar redundancia (built-in sanity check).
- Dois esquemas são amplamente utilizados:
 - RSA-**OAEP** — adoptado para Public-Key Encryption;
 - RSA-**PSS** — adoptado para Assinaturas.
- E.g. OAEP (Optimal Asymmetric Encryption Padding):



- Ambos os esquemas asseguram níveis de segurança muito fortes (sob a assumção RSA).

El-Gamal

- Algoritmo PKE introduzido em 1984 by *T. El Gamal*.
- Segurança é baseada no problema do logaritmo discreto.
- Descrição:

Parametros: primo p um gerador g ordem prima q .

- KeyGen(p, g):
 - gerar um número aleatório x t.q. $0 < x < q$;
 - retornar (sk, pk) , onde a chave privada é $sk = x$; e chave pública $pk = g^x$.
- Enc(pk, m) = $+k, (g^k \bmod p, (m * pk^k) \bmod p)$
- Dec($sk, c=(a,b)$) = $b / a^{sk} \bmod p$

- Obs:
 - operação de cifrar é um algoritmo randomizado;
 - criptograma duplica tamanho do texto limpo;
 - Tamanho de chaves: similar ao RSA.

Segurança do El-Gamal

- Derivar a chave privada da chave pública corresponde exatamente ao problema do logaritmo discreto.
- A cifra demonstra-se “semanticamente segura” sob ataques de texto limpo escolhido: um adversário (PPT) não consegue distinguir os textos cifrados de dois textos limpos por si escolhidos (*Ciphertext Indistinguishability under Chosen Plaintext* — **IND-CPA**).
- Um esquema com grande relevância acadêmica, mas pouco impacto prático.

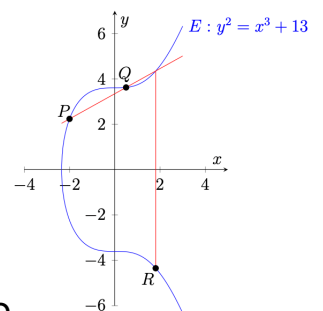
Digital Signature Algorithm (DSA)

- Algoritmo de assinatura incluído no Digital Signature Standard (DSS) - 1991.
- Desenvolvido pelo NSA para a NIST.
- Segurança baseada na dificuldade do logaritmo discreto (como o El-Gamal).
- Projetado para fornecer um procedimento de assinatura muito eficiente — por exemplo, muito mais eficiente do que o RSA... (por outro lado, a verificação é muito mais pesada).
 - Portanto, é particularmente adequado para funcionar em ambientes com recursos limitados (e.g. smartcards).

Criptografia baseada em Curvas Elípticas

Elliptic-Curve Cryptography (ECC)

- O problema do "logaritmo discreto" pode ser expresso em qualquer corpo finito (e.g. $\text{GF}(p)$ or $\text{GF}(p^n)$).
- Mas também pode ser "transposto" para um grupo cíclico definido numa curva elíptica definida sobre tais corpos.
- Na Criptografia baseada em Curvas Elípticas (ECC), a operação correspondente à exponenciação modular é “multiplicação escalar ($k \cdot P$)”...
- ...cuja operação inversa é o que se designa por “Elliptic Curve Discrete Logarithm (ECDL)”.
- ...que também é considerado um problema difícil (se os parâmetros de curva subjacentes atenderem a determinados critérios).
- Variantes das primitivas baseadas no problema do Logaritmo Discreto podem, portanto, ser definidas para operar em Curvas Elípticas (e.g. ECDH; ECDSA; etc.).



ECC security

- A grande vantagem da criptografia baseada em curvas elípticas é que permite alcançar os níveis desejados de segurança com chaves muito mais pequenas.
- Um aspecto crítico (e controverso) da ECC é a escolha dos parâmetros (parâmetros de curva e escolha do ponto base).
 - A natureza dos critérios exigidos nessas decisões, assim como o esforço computacional normalmente envolvido, significam que a única maneira viável de adoptar ECC é usar parâmetros tabelados (padronizados).
 - Possíveis escolhas:
 - NIST-P (e.g. P-256; P-384; P-521) — (propostas pela NSA);
 - Brainpool — parametros aleatórios — proposta pela BSI;
 - Curve 25519 — proposta por *D. Bernstein*.

NIST guidelines for public key sizes for AES			
ECC KEY SIZE (Bits)	RSA KEY SIZE (Bits)	KEY SIZE RATIO	AES KEY SIZE (Bits)
163	1024	1 : 6	
256	3072	1 : 12	128
384	7680	1 : 20	192
512	15 360	1 : 30	256

Supplied by NIST to ANSI X9F1

Criptografia & Computação Quântica

Computação Quântica & Criptografia

- A computação quântica faz uso das leis e fenômenos da mecânica quântica para resolver problemas computacionais.
- A consequência é que, neste novo paradigma, certos problemas que são considerados difíceis podem ser resolvidos de forma eficiente (ou com ganhos significativos de eficiência).
- O **impacto na criptografia simétrica é significativo, mas não catastrófico**. Decorre da aceleração quadrática que resulta do algoritmo de *Grover* para pesquisa não estruturada.
- Mas na criptografia assimétrica, as consequências são críticas, já que a generalidade dos "problemas difíceis" adotados actualmente tem soluções eficientes (usando o algoritmo de Shor), a saber:
 - Factorização (RSA)
 - Logaritmo Discreto (Diffie-Hellman, ElGamal, DSA)
 - Logaritmo Discreto em Curvas Elípticas (ECDH, ECDSA, EdDSA, etc.)

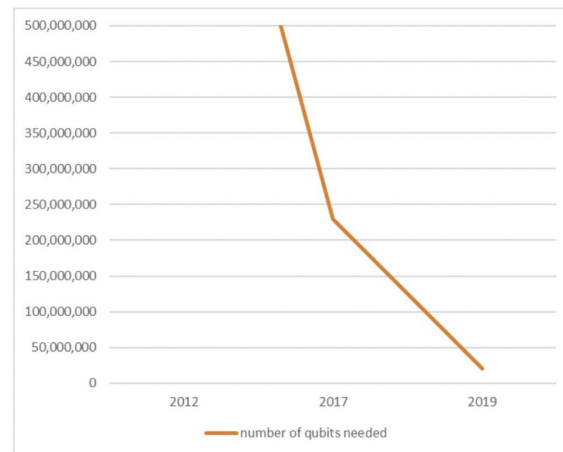
Previsões para o destino anunciado...

- Os computadores quânticos de hoje ainda estão longe de poder ter impacto a segurança dos algoritmos/tamanhos de chave usados actualmente.
- Mas o investimento em pesquisa de computação quântica é enorme...
- ...pelo que se prevê que por volta de 2030 seja possível quebrar o RSA-2048.
- ...o que representa **uma ameaça real hoje**:

Informações confidenciais cifradas podem estar a ser colectadas hoje para que possam ser quebradas num futuro próximo com CQ.
- Essas previsões levaram as organizações de standards a promover a atualização da criptografia para a tornar resistente à ameaça da computação quântica.

Ataque ao RSA-2048?

- O algoritmo de Shor mostra-nos que um computador quântico com 3074 qubits perfeitamente estáveis será capaz de quebrar o RSA-2048 em 10 s.
- Computadores quânticos reais estão muito longe desses requisitos:
 - Número de qubits;
 - Taxa de erro associadas;
 - Tempo de coerência
- Alguns artigos recentes sobre o tema:
 - C. Gidney & M. Eker (2019): “How to factor 2048 bit RSA integers in 8 hours using 20 million noisy qubits”
 - C. Gidney (2025): “How to factor 2048 bit RSA integers with less than a million noisy qubits”
 - P. Gutmann & S. Neuhaus: “Replication of Quantum Factorisation Records with an 8-bit Home Computer, an Abacus, and a Dog”
 - D. Willsch et al (2025): “The State of Factoring on Quantum Computers”
- Também se questiona se o algoritmo de Shor será o contributo mais promissor da computação quântica para quebrar o RSA
- ...em particular, se outras abordagens mais limitadas de computação quântica (Quantum Annealing) não irão contribuir de forma mais efectiva para esse objectivo.
- Em resumo: previsão situa-se tipicamente por volta de 2030 (mas margem para cepticismo ainda é cientificamente defensável!).



Post-Quantum Cryptography (PQC)

- Superar os problemas que a CQ representa para a segurança das técnicas criptográficas atuais não significa basear a criptografia em computadores quânticos!
- **Post-Quantum** (ou **Quantum-Safe**) **cryptography** refere-se a técnicas criptográficas clássicas que são seguras contra adversários quânticos (i.e., que disponham de acesso a um computador quântico).
- O desafio é encontrar "problemas difíceis" que resistam à computação quântica.
- Domínios onde se acredita que certos problemas sejam “Quantum Safe”:
 - Reticulados
 - Sistemas de equações multi-variável
 - Criptografia baseada em Funções de Hash
 - Criptografia baseada em Códigos
 - Isogenias em curvas elípticas super-singulares
- ...com diferentes compromissos na confiabilidade; margem de segurança; tamanhos de assinatura e PKs; eficiência; etc..

Transição para Quantum-Safe

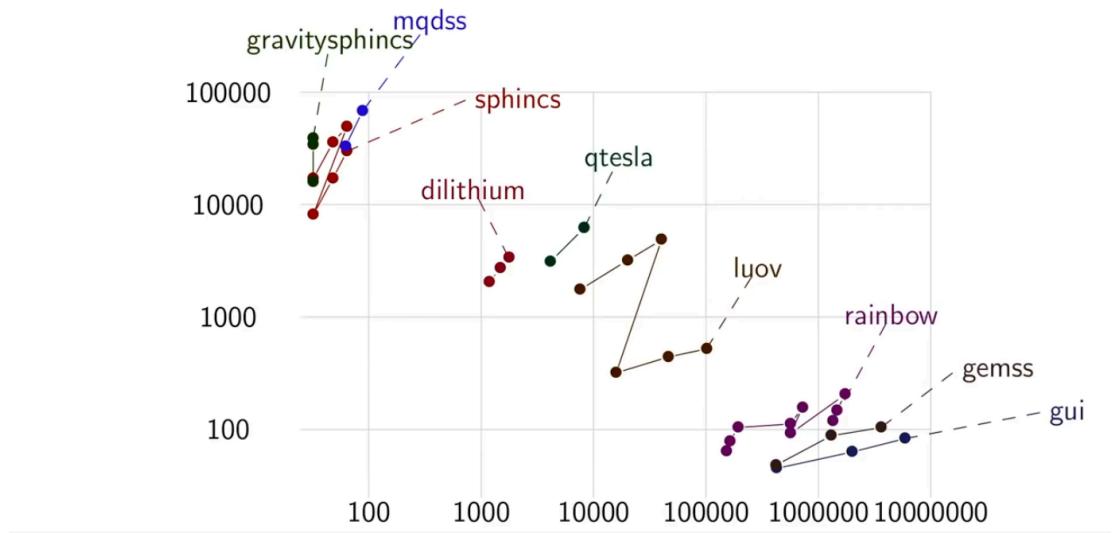
- Tem havido um esforço apressado para promover a transição para as técnicas criptográficas Post-Quantum.
- Mas PQC precisa de "tempo" para se tornar uma alternativa viável em aplicações criptográficas:
 - Confiança (e.g. pesquisa em cripto-análise)
 - Novas Implementações
 - Usabilidade e inter-operabilidade (e.g., redesenhar protocols, etc.)
 - Desenvolvimento de Standards
- Por outro lado, a transição deve ser o mais cedo possível para que, quando um computador quântico for capaz de comprometer alguns dados, ele não seja mais sensível.
- EU Roadmap for the Transition to Post-Quantum Cryptography:
 - final **2026**: os Estados-Membros devem estabelecer roteiros nacionais de PQC e lançar pilotos para casos de uso de alto e médio risco;
 - final **2030**: A transição de casos de uso de alto risco deve ser concluída. Atualizações de software e firmware com segurança quântica devem ser o padrão;
 - **2035**: PQC deve ser implementado na maioria dos sistemas de baixo/médio risco.

Processo de Standards PQC

- Iniciativa NIST para padronização PQC (anúncio: 2016; seleção final de candidatos: 2022)
- A natureza da chamada NIST PQC é diferente das chamadas anteriores (AES, SHA-3, ...):
 - A criptografia pós-quântica é mais complicada!
 - Os requisitos/linha do tempo variaram dependendo dos avanços na área.
 - Não havia pesquisa suficiente em Computação Quântica para fornecer confiança em relação às diferentes propostas...
 - "No silver bullet! — Não se esperava que resultasse em "pick a winner"
 - Idealmente, uma seleção de "boas alternativas"
 - Substituições drop-in fáceis eram assumidamente improváveis
- Standards Actuais:
 - FIPS 203, *Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM)* — [CRYSTALS-KYBER]
 - FIPS 204, *Module-Lattice-Based Digital Signature Standard (ML-DSA)* — [CRYSTALS-Dilithium]
 - FIPS 205, *Stateless Hash-Based Digital Signature Standard (SLH-DSA)* — [SPHINCS+]
- Outras iniciativas de padronização em andamento...

Sizes...

Signature size (y axis) vs. public-key size (x axis)



Esquemas Híbridos

- O uso de esquemas híbridos é recomendado em um estágio inicial na adoção do PQC.
- Um Esquema Híbrido combina criptografia clássica com PQC:
 - E.g. para assinaturas: RSA-4096 + Dilithium-3
- Vantagens:
 - Interoperabilidade/compatibilidade com sistemas "legacy"
 - Protege o risco associado à novidade da técnica PQC
 - Segurança: pelo menos tão seguro quanto o melhor dos esquemas combinados
- Desvantagens:
 - Ainda torna os problemas resultantes do tamanho mais pronunciados (chave pública, assinatura, etc.)
 - Redundância ("computational overhead", etc.)

...do ponto de vista das organizações (Segurança da Informação)

- (source: DHS/NIST post-quantum cryptography guidance):

1. Organizations should direct their Chief Information Officers to increase their engagement with standards developing organizations for latest developments relating to necessary algorithm and dependent protocol changes.
2. Organizations should inventory the most sensitive and critical datasets that must be secured for an extended amount of time. This information will inform future analysis by identifying what data may be at risk now and decrypted once a cryptographically relevant quantum computer is available.
3. Organizations should conduct an inventory of all the systems using cryptographic technologies for any function to facilitate a smooth transition in the future.
4. Cybersecurity officials within organizations should identify acquisition, cybersecurity, and data security standards that will require updating to reflect post-quantum requirements.
5. From the inventory, organizations should identify where and for what purpose public key cryptography is being used and mark those systems as quantum vulnerable.
6. Prioritizing one system over another for cryptographic transition is highly dependent on organization functions, goals, and needs.
7. Using the inventory and prioritization information, organizations should develop a plan for systems transitions upon publication of the new post-quantum cryptographic standard. Cybersecurity officials should provide guidance for creating transition plans.